

Préparation — Projet « Des agents IA pour analyser les risques » (E21)

Sources : E21_..._Projet_Agents_IA_pour_l'analyse_de_risques.pdf (30 p.)

E21_..._Support_CISSP_Partie_1_compressed.pdf (117 p.)

1. Cadre à respecter (non négociable)

Élément	Modalité
Travail	Groupe de 4 étudiants
Durée	1h : 45 min de soutenance + 20 min de questions
Outils	Tout LLM / framework d'agents / no-code, à condition de le citer
Cas d'étude	A, B ou C, ou cas propre validé par l'enseignant
Rendu	Dossier écrit + prototype ou maquette + soutenance
Éléments [...]	Fixés par l'enseignant au lancement (poids des critères...)

Les 3 livrables en détail

1. **Dossier écrit** : description du cas · architecture + fiche de chaque agent · consignes (prompts) utilisées · registre des risques obtenu · analyse critique des résultats.
2. **Prototype / maquette** : code, flux no-code ou maquette détaillée · exemple d'exécution sur le cas · **traces des échanges entre agents**.
3. **Soutenance** : présentation de l'architecture · démonstration · ce qui marche / ne marche pas · les risques de votre propre système d'agents.

Critères d'évaluation (poids = enseignant)

- Maîtrise de la démarche de risque
- Qualité de l'architecture (rôles clairs, échanges structurés, orchestrateur pertinent)
- Choix et justification du modèle de menaces
- Sécurité du système d'agents (risques IA identifiés et traités)
- Esprit critique (comparaison avec l'analyse manuelle, limites expliquées)
- Restitution (dossier clair, démo, réponses)

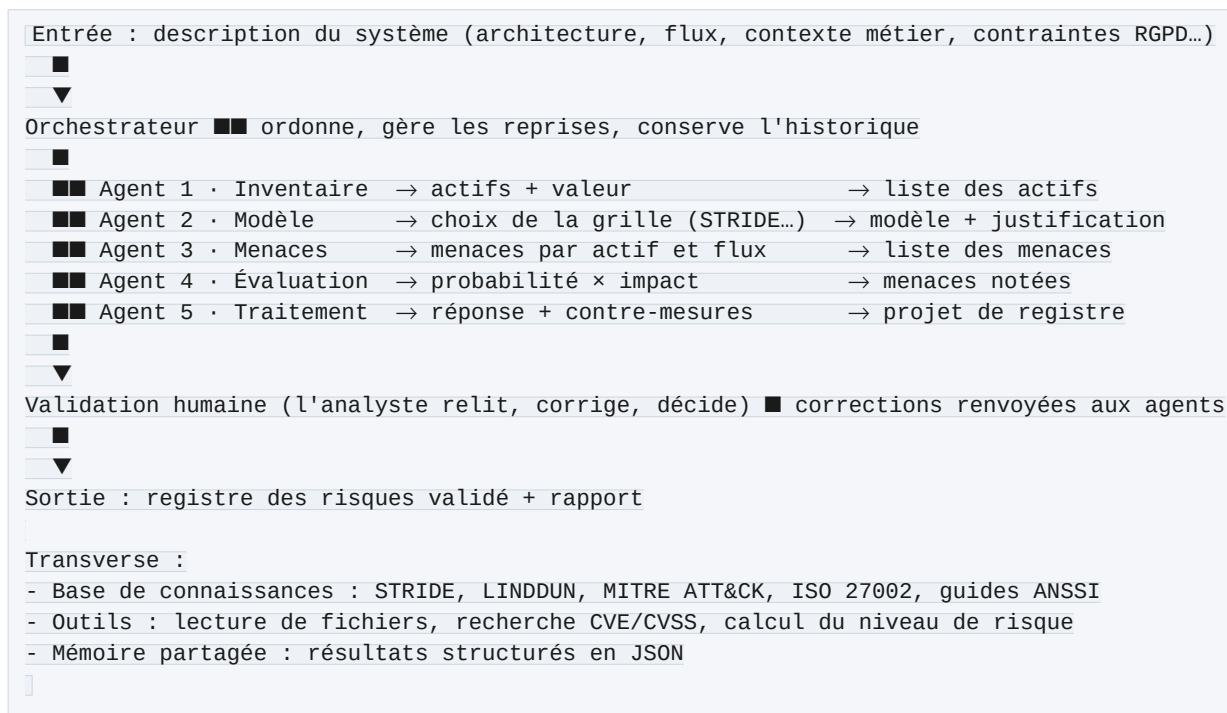
Liste de contrôle avant rendu (p. 28)

- [] Chaque risque cite actif, menace, niveau **et source**
- [] Choix du modèle justifié par le cas étudié
- [] Un humain a validé chaque risque avant rendu
- [] Comparaison agents ↔ analyse manuelle faite
- [] Test d'une consigne piégée (prompt injection) fait

- [] Aucune donnée réelle sensible envoyée à un service IA externe
- [] Tous les outils d'IA utilisés sont cités

2. Le système à construire

Architecture cible (p. 20)



Fiches agents (p. 21)

Agent	Reçoit	Fait	Produit
1 · Inventaire	description du système	repère/classe les actifs, estime leur valeur	liste des actifs
2 · Modèle	liste des actifs + contexte	choisit la grille et la justifie	modèle retenu + justification
3 · Menaces	actifs + modèle	applique la grille à chaque actif/flux	liste des menaces
4 · Évaluation	menaces	note P et I, calcule le niveau	menaces notées
5 · Traitement	menaces notées	propose réponse et contre-mesures	projet de registre
Orchestrateur	demande de l'analyste	lance les agents dans l'ordre, gère les reprises	historique complet

→ Chaque agent a sa propre consigne (prompt), écrite par le groupe : c'est une partie importante du rendu.

Format d'échange JSON (p. 22)

```
{
  "id": "R-07",
  "actif": "Console d'administration",
  "menace": "Vol d'identifiants par hameçonnage",
  "categorie": "STRIDE-S",
  "probabilite": "moyenne",
  "impact": "élevé",
  "niveau": "élevé",
  "traitement": "réduire",
  "mesures": ["MFA FID02", "sensibilisation"],
  "sources": ["STRIDE", "OWASP ASVS V2"],
  "valide_par": null
}
```

- `sources[]` obligatoire → 1re parade contre l'hallucination.
- `valide_par` reste `null` tant qu'un humain n'a pas validé.

Garde-fous imposés (p. 20)

1. Filtrage des entrées (injection de prompt)
2. Outils **en lecture seule**
3. Anonymisation des données
4. Sources citées pour chaque risque
5. Journalisation de toutes les actions

Risques du système d'agents à documenter (p. 17)

Risque	Mesure
Hallucination	exiger des sources, validation humaine
Injection de prompt	filtrer les entrées, séparer consignes et données (OWASP LLM Top 10 #1)
Fuite de données	anonymiser, modèle local
Excès d'autonomie	lecture seule, humain dans la boucle
Empoisonnement de la base	sources officielles, contrôle des mises à jour
Dépendance fournisseur	architecture modulaire, modèle remplaçable

3. Cadre méthodologique (depuis le cours)

Vocabulaire exact

Actif · menace · agent de menace · vulnérabilité · exposition · risque · contre-mesure · attaque · violation (breach) · incident · risque inhérent / résiduel · appétence / tolérance.

Risques zéro n'existe pas. Risque = Menace × Vulnérabilité × Impact. Le risque résiduel n'est jamais nul → acceptation **explicite et formelle** par la direction.

Évaluation

- **Qualitative** : matrice Probabilité × Impact (échelles faible/moyen/élevé/critique), avis d'experts, méthode Delphi → pour trier.
- **Quantitative** : $AV \times EF = SLE$; $SLE \times ARO = ALE$; valeur d'une mesure = $ALE_{avant} - ALE_{après} - ACS$ (si > 0 , rentable) → pour les risques majeurs.
- Pratique : **hybride** — qualitative pour trier, quantitative pour le portefeuille.
- Alternatives de notation : **DREAD** (5 critères) ou **CVSS v4.0** (0–10). *Choisir une et justifier.*

Les 4 traitements

Réduire · Transférer · Éviter · Accepter. **Ignorer = jamais acceptable.** Transférer ne transfère pas la responsabilité.

Modélisation des menaces (ch. 6 + 10)

4 questions de Shostack : sur quoi travaille-t-on ? qu'est-ce qui peut mal tourner ? que fait-on contre cela ? avons-nous fait du bon travail ?

Processus 6 étapes : périmètre → DFD → frontières de confiance → grille → prioriser → réduire/valider.

Les attaques se produisent surtout au passage des **frontières de confiance**.

Choix du modèle (p. 12 projet / p. 108 cours) | Situation | Modèle | |---|---| | Par défaut, dès la conception, avec les développeurs | **STRIDE** | | Beaucoup de données personnelles / RGPD | **LINDDUN** | | Relier aux enjeux métier | **PASTA** (7 étapes) | | Scénario d'attaque précis à détailler | Arbres d'attaque (racine = objectif) | | Comparer aux attaques réelles / SOC | **MITRE ATT&CK** | | Prioriser rapidement / correctifs | DREAD ou CVSS | | Évaluer toute une organisation | OCTAVE |

Chaîne de combinaison recommandée (p. 109) — à réutiliser comme fil de l'architecture : 1. Décrire (DFD + frontières) → 2. Identifier (STRIDE, +LINDDUN si données perso) → 3. Détailler (arbres d'attaque + ATT&CK) → 4. Prioriser (DREAD/CVSS) → 5. Traiter.

STRIDE ↔ propriétés

Lettre	Menace	Propriété violée	Contre-mesure type
S	Usurpation (spoofing)	Authenticité	MFA, certificats
T	Falsification (tampering)	Intégrité	Signature, hachage
R	Répudiation	Non-répudiation	Journaux horodatés
I	Divulgateion	Confidentialité	Chiffrement, contrôle d'accès
D	Déni de service	Disponibilité	Redondance, limitation de débit
E	Élévation de privilèges	Autorisation	Moindre privilège

Registre des risques (colonnes retenues)

Identifiant + description · actif concerné (+ propriétaire) · catégorie de menace (STRIDE) · probabilité · impact · niveau · traitement + contre-mesures · justification + sources · risque résiduel + validation (*valide_par*) [+ échéance de revue].

4. Cas d'étude au choix

Cas	Description	Actifs à ne pas oublier
A	Boutique en ligne d'une PME (site, paiement tiers, base clients, back-office)	données clients, compte admin, disponibilité
B	Téléconsultation médicale (RDV + visio patients/médecins)	données de santé, identités, flux vidéo
C	Réseau d'une PME (postes, messagerie, fichiers, Wi-Fi, RDS)	comptes, sauvegardes, VPN

→ **Avant tout** : rédiger la description d'une page (architecture + flux) = entrée du système. → **Avant tout aussi** : faire l'analyse de risques **à la main** sur quelques actifs = référence pour juger les agents.

5. Plan de travail proposé (5 jalons du sujet)

1. **Cadrer** — choisir le cas, description 1 page (DFD + frontières de confiance), liste d'actifs, référence manuelle.
2. **Concevoir** — schéma d'architecture, fiche + prompt de chaque agent, schéma JSON, garde-fous.
3. **Prototyper** — chaîne fonctionnelle sur le cas choisi (code ou no-code), base de connaissances, journal des échanges.
4. **Tester** — comparaison agent vs analyse manuelle (écarts, omissions, inventés) ; **test d'injection de prompt**.
5. **Restituer** — dossier, démo, slides 45 min, section « risques de notre propre système ».

Pistes de garde-fous techniques

- Séparation stricte *système / données* dans chaque prompt (le document analysé est du **donnée**, jamais de l'instruction).
- Validation JSON schema stricte entre agents (rejet = relance orchestrateur).
- Refus des sources non citées : `sources[]` vide → risque rejeté.
- Outils : lecture seule + liste blanche (pas d'exécution, pas d'écriture en base).
- Anonymisation avant tout appel à un modèle externe ; journal horodaté de chaque appel (acteur, agent, entrées, sorties).
- `valide_par` non renseignable par les agents (humain uniquement).

6. Références à citer dans le dossier

ISO/IEC 27005 · ANSSI EBIOS Risk Manager · NIST SP 800-30 · A. Shostack, *Threat Modeling* (2014) · STRIDE · LINDDUN (KU Leuven) · MITRE ATT&CK · NIST NVD (CVE/CVSS v4.0, FIRST) · OWASP Top 10 for LLM Applications (2025) · MITRE ATLAS · ANSSI recommandations IA générative (2024) · AI Act · RGPD · ISO/IEC 27002 · ISO 27001 (PDCA).

7. Points à trancher avec l'équipe

- [x] Cas d'étude : **B** (téléconsultation médicale → LINDDUN pertinent en plus de STRIDE)
- [x] Modèle de menaces de base : **STRIDE + LINDDUN** (données de santé)
- [x] Notation : **matrice P×I** (le niveau est calculé par une matrice déterministe, jamais laissé à l'IA — garde-fou G7)
- [x] Qualitatif + quantitatif **hybride** avec quelques ALE sur les actifs critiques (ex. R-04 : ARO 0,2/an → ALE 36 000 €/an, valeur de la mesure +18 000 €/an)
- [x] Forme du prototype : **Python + CLI** (`run.py`), fournisseur `dummy` ■ API OpenAI-compatible, agents AG1→AG5 pilotés par un orchestrateur
- [x] Modèle(s) LLM visés — cités au § 9 du dossier (doc 05) : `gpt-4o-mini` (API OpenAI-compatible), génération assistée **OpenCode v2.0.15**, Python 3.13.5, pytest 9.1.1, jsonschema 4.26.0, Markdown 3.10.3 + xhtml2pdf 0.2.20 / weasyprint 70.0 / PyMuPDF 1.28.2 (`md_to_pdf.py`), git 2.47.3
- [] Répartition des 4 membres sur les 5 jalons (à finaliser)

8. État d'avancement (2026-09-24 — après audit et corrections)

- **Tests : 86 tests pytest verts** (8 fichiers dans `prototype/tests/`), dont `test_comparaison.py` (avant audit : 52 tests, 7 fichiers).
- **Injection de prompt** (`cases/casB_injecte.md`) : **14 consignes piégées → 14/14 détections mesurées** (une par occurrence), **9 familles de motifs** (`ignore_instructions`, `disable_securite`, `override_system`, `nouvelle_persona`, `delimiteur_injecte`, `data_as_instruction`, `jailbreak_mot`, `disclose_secrets`, `replay_prompt`). Le sanitizer couvre **FR + EN + paraphrases + obfuscation** (espaces inter-lettres, caractères zero-width, homoglyphes cyrilliques/fullwidth), neutralise les balises `<<<...>>>`, utilise des **délimiteurs aléatoires uniques par session** et a corrigé ses faux positifs (« désormais », « Dorénavant », « Consignes : »). Avant audit : « 13 consignes, 4 motifs détectés ».
- **Comparaison (jalon 4)** : commande CLI `--comparer` qui confronte le registre généré à la référence manuelle structurée `prototype/data/reference_manuelle.json` (export de 03). En dry-run le 10/10 est **tautologique par conception** — assumé et affiché (« ■■ mode dummy : comparaison tautologique par conception ») ; le fournisseur dry-run se nomme **dummy-deterministic (test de chaîne – n'est PAS une analyse)**. Preuve de non-tautologie : `FournisseurSimule(fidele=False)` produit un registre valide mais divergent (R-07 oublié, R-11 inventé, écart de niveau R-09) que la comparaison détecte (`tests/test_comparaison.py`). Comparaison réelle : `--provider openai`.
- **Validation humaine** : trace de référence `runs/run-20260924-095723/` — décisions mixtes signées Dr Dupont : R-01 corrigé (champs impact + source, niveau recalculé par la matrice), R-02→R-09 acceptés, R-10 différé (`valide_par` reste null). L'ancienne trace `runs/run-20260923-175812/` est reléguée à « démonstration mécanique du flux ». Octets réellement envoyés mesurés dans le journal : AG1 5 048 → AG5 11 289.
- **Autres traces** : `runs/run-20260924-095714/` (dry-run cas B + `--comparer`), `runs/run-20260924-095718/` (document piégé, **14 injections journalisées**).
- **Erreurs de fond corrigées (ne pas réintroduire)** : CVE-2023-4863 (libwebp) = **débordement de tas (heap buffer overflow)** — et non « pile » ; ISO 27002:2022 **A.5.18** = « **Droits d'accès** », **A.8.2** = « **Accès privilégié** » ; risques résiduels = **3 faibles + 7 moyens** (jamais « aucun résiduel faible ») ; R-04 = « Rançongiciel : perte irréversible des dossiers », ARO 0,2/an → ALE 36 000 €/an, valeur mesure +18 000 €/an.

- **Publication** : les artefacts (docs 01→09 .md/.pdf, PREPARATION.md, outils/, runs/, knowledge/, data/) sont **re-publics sur GitHub** github.com/PlayerFann14/tpmgtsecu (branche `main`).